COMISIÓN PARA EL MERCADO FINANCIERO

Regulador y Supervisor Financiero de Chile

Presentación Sandbox Tecnológico Pre-Productivo ATENA

finanzasabiertas
COMISIÓN PARA EL MERCADO FINANCIERO

Comisión para el Mercado Financiero
Enero 2026

Agenda

01 Contexto

02 Arquitectura del Sandbox y su integración con el Directorio

03 Principios de Diseños y Flujos de Seguridad para las pruebas

04 Kick Off: Acceso a entorno pre-productivo

Agenda

01 **Contexto**

02 Arquitectura del Sandbox y su integración con el Directorio

03 Principios de Diseños y Flujos de Seguridad para las pruebas

04 Kick Off: Acceso a entorno pre-productivo

Se han logrado avances concretos en la implementación del SFA. Hoy el foco está en las pruebas pre-productivas para la liberación de esta infraestructura clave

Ene.23
Publicación
Ley Fintec

Ene.24
- Instalación Foro del Sistema de Finanzas Abiertas.
- Grupos Técnicos: Medio de intercambio, Ciberseguridad, UX e Infraestructura.

Abr-May-24
Consulta Pública NCG 514:
213 comentarios desde 47 entidades

Jul.24
NCG 514 que regula el SFA

Jun-Jul.25
1ª Consulta pública Anexo 3
+400 comentarios desde 32 entidades

Nov-Dic.25
Consulta Pública
modificaciones NCG 514

Ene.26
2ª Consulta pública
Anexo 3

Ene-Jun 26
Pruebas Sandbox Tecnológico y Directorio

XX.26
NCG514 - Anexo 3 definitivo

Lo que viene:
- **Entrada en vigencia de la NCG 514**
- **Habilitación Sandbox Tecnológico**
- **Marcha Blanca**
- **…**

Desarrollo de infraestructuras: directorio y sandbox tecnológico

Reuniones de Lobby y reuniones con externos: expertos internacionales, reguladores externos y organismos multilaterales (Banco Mundial y BID)

Para el período de pruebas pre-productivas, se invitó a los participantes del Foro del SFA

La preparación para las pruebas será abordada en tres sesiones

Sesión 1
Arquitectura del Sandbox y su integración con el Directorio

- Introducción
- Topología de componentes (Sandbox, Directorio, Entidad Financiera)
- Roles y tipo de interacciones entre cada uno de los actores
- Registro en el directorio y manejo de certificados de seguridad
- Roles del Sandbox Pre-Productivo y tipo de Interacción

Sesión 2
Principios de Diseños y Flujos de Seguridad

- Contratos OpenAPI 3 – principios de diseño
- Comunicación de eventos Direcotorio y Grant Management
- Autenticación mTLS + OAuth/OIDC
- Principios de seguridad del Perfil Chileno FAPI 2.0
- Conexión y captura del consentimientos (RAR)

Sesión 3
DEMO (Fecha por definir)

- Cercano a la fecha de inicio del período de pruebas se realizará lo siguiente:
  - Proceso de alta para generación de accesos al directorio
  - Tipos de pruebas a ejecutar (esperables y evidencias)
  - Niveles de soporte durante el proceso de pruebas
  - Información sobre equipo de soporte
  - DEMO de utilización del ambiente de pruebas

Expositores Sesiones de Preparación Pruebas del Sandbox Tecnológico ATENA

Eduardo Oñate
Director General de Tecnologías de la Información

Roberto Celis
Jefe de proyecto

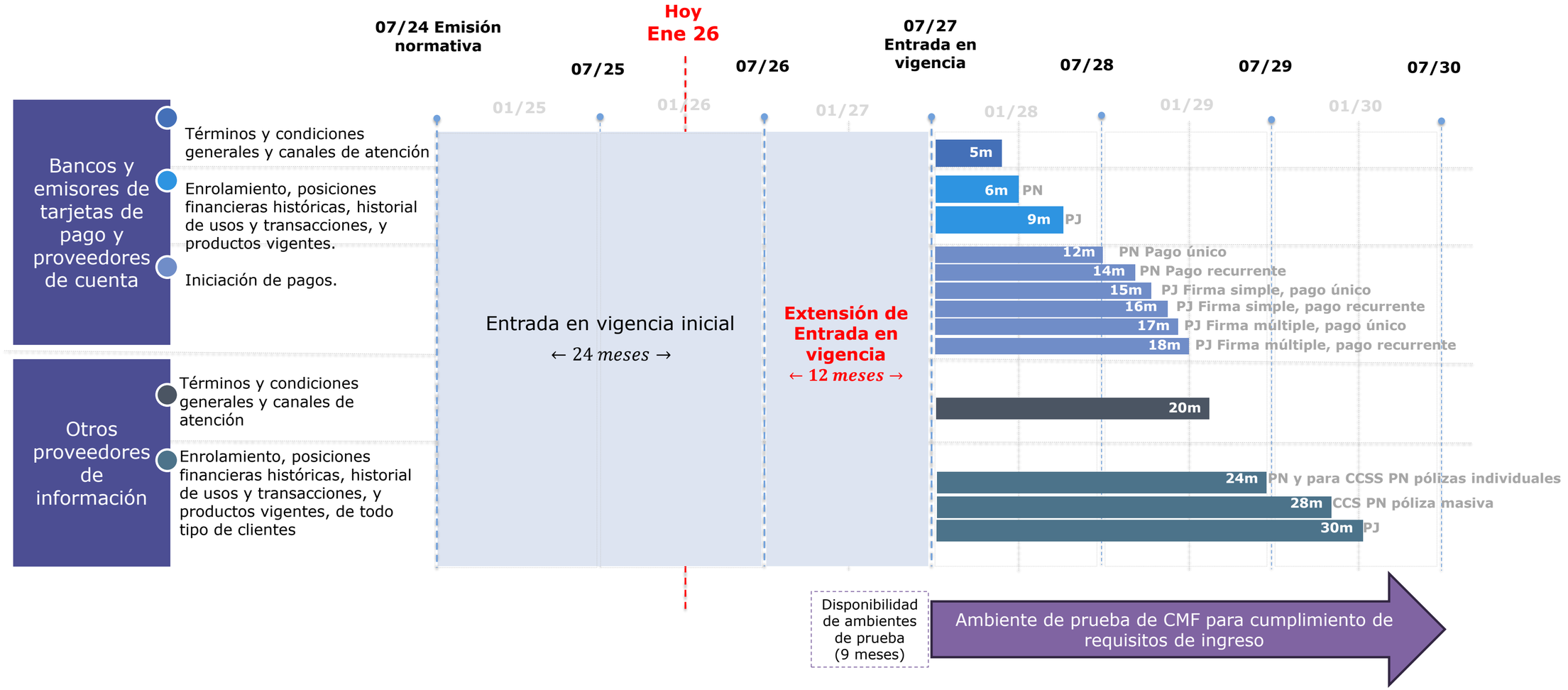
Jonathan Lema
Open Finance Manager

Rodrigo Escapa
Arquitecto Open Finance

Mikael Fernandes
Product Owner

Jaime Guerrero
Arquitecto de Soluciones

Para la implementación del SFA se propuso un calendario de implementación gradual en un horizonte de 5 años



* Se considera la reducción desde 90 a 60 días en el plazo de inscripción de las IPI del Grupo 1, y desde 18 a 15 meses para las entidades del Grupo 2.

Agenda

01 Contexto

02 **Arquitectura del Sandbox y su integración con el Directorio**

03 Principios de Diseños y Flujos de Seguridad para las pruebas

04 Kick Off: Acceso a entorno pre-productivo

Presentación Sandbox Tecnológico ATENA

Introducción

Objetivo de las capacitaciones técnicas (Sandbox + Directorio)

- Utilizar el **Sandbox Tecnológico ATENA** como entorno de pruebas controlado y acotado para la validación de integraciones técnicas, sin uso de datos productivos ni personales.
- **Incorporar tempranamente a los participantes** (IPI/IPC/PSBI/PSIP) al uso de ATENA, con el **objetivo de detectar brechas técnicas, y oportunidades de mejora** antes de la entrada en vigencia de la normativa.
- Facilitar un acercamiento práctico a la infraestructura exigida por el modelo de Finanzas Abiertas: arquitectura lógica, componentes, roles, flujos de interacción y dependencias con el Directorio.
- Presentar un marco común de **seguridad por diseño** para pruebas: conectividad segura, autenticación/autorización y trazabilidad
- **Preparar la ejecución de pruebas end-to-end:** credenciales/certificados, colecciones (Postman), matriz de evidencias y reglas operacionales del entorno

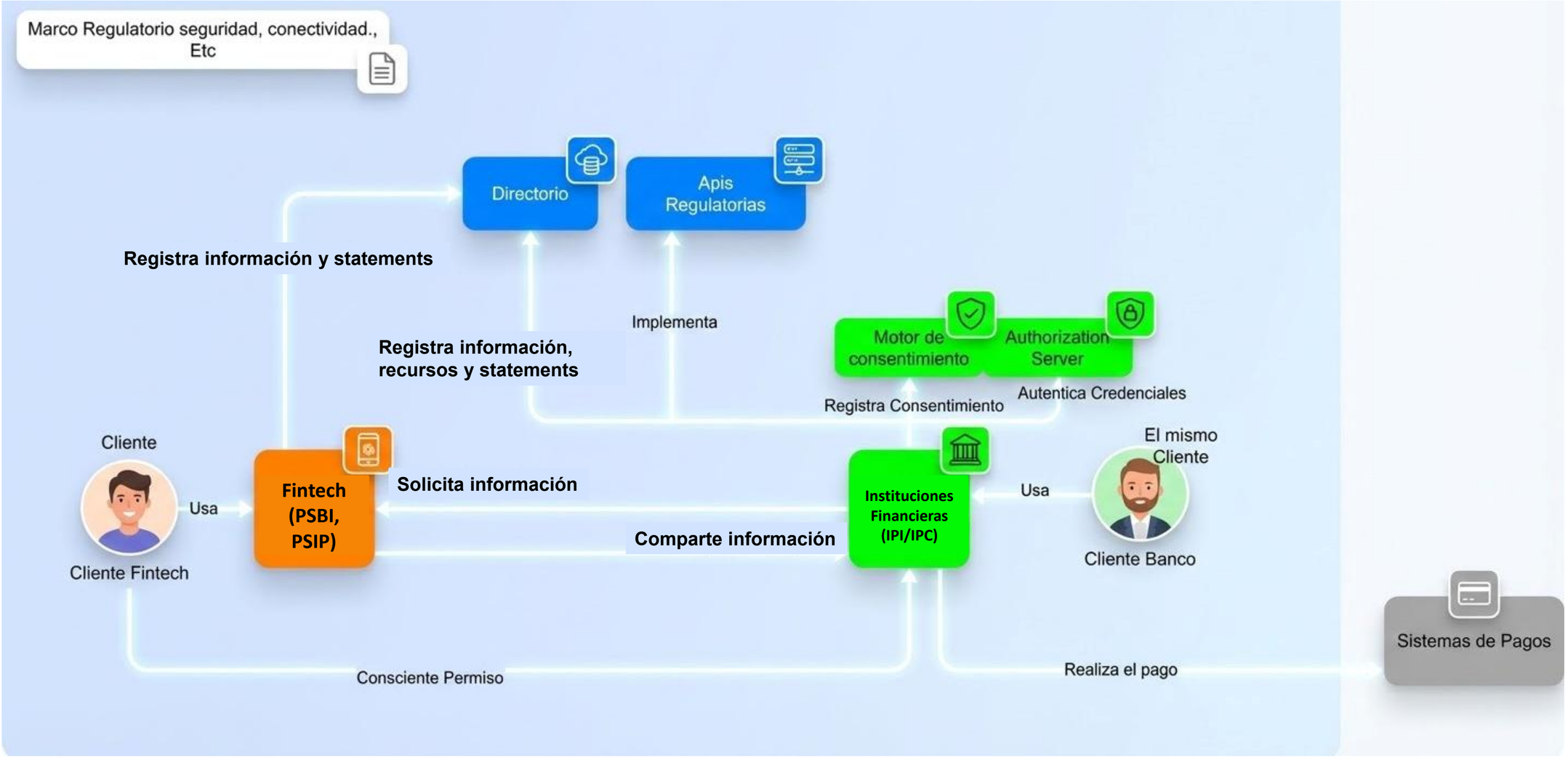
¿Qué se verá en la sesión de hoy?

- **Sesión 1:** Arquitectura del Sandbox/Directorio, roles e interacción, conectividad y certificados

Todas las especificaciones realizadas se han realizado tomando como punto de partida las definiciones realizadas en los grupos técnicos

Arquitectura del Sandbox y su Integración con el Directorio

Ecosistema de Finanzas Abiertas



Arquitectura del Directorio y Sandbox del SFA

Arquitectura de alto nivel

Directorio de Participantes

PSBI/PSIP

- Solicitud de registro y accesos
- Inscripción de certificados

IPI/IPC

- Registro de servidor de autorización
- Sincronización con el directorio

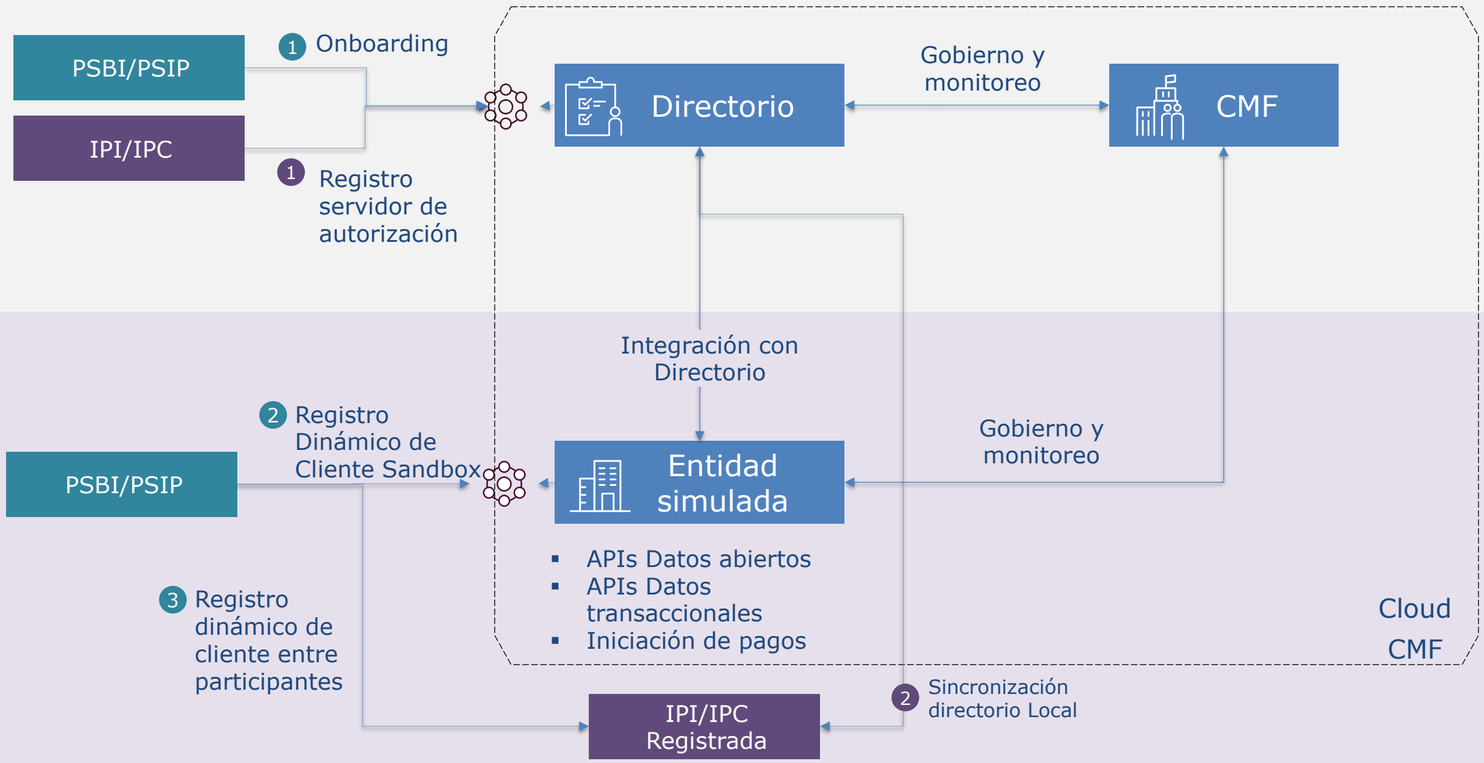
Sandbox y Portal del desarrollador

PSBI/PSIP

- Consumo APIs entidad simulada
- Registro dinámico de clientes

PSBI/PSIP – IPI/IPC

- Descarga de OAS3.1
- Feedback y foro de discusión



Arquitectura del Directorio y Sandbox del SFA

Principales Funcionalidades

Directorio (Web Application)

1. Permite que usuarios Administradores de instituciones financieras participantes que configuren datos de:
   - **Declaración de software:** es la identidad de una aplicación
   - **Certificados digitales:** documentos que sirven como llave de seguridad**;**
   - **Servidores de autorización:** gestiona permisos como consentimientos y tokens**;**
   - **Recursos de API y endpoints:** puntos o direcciones de contacto**;**

2. Además de agregar nuevos usuarios a su institución participante.
   - **Rol de usuario:** visualiza datos de institución;
   - **Rol de administrador:** gestiona datos de institución;

Sandbox de Pruebas

1. Permite al **PSBI/PSIP realizar consumo de las APIs desplegadas** dentro del SFA de Chile
2. Para acceder a las APIs los participantes deberán realizar un **registro dinámico de cliente**, lo que les permitirá acceder a los APIs expuestas por el Sandbox
3. Se proporcionará **colecciones de postman** para facilitar los consumos por parte de los participantes

Portal del desarrollador

1. Permite a los usuarios visualizar todas las documentaciones **de los casos de uso regulatorios** para el SFA
2. Contiene los **estándares técnicos para todos los APIs** que deberán ser desplegadas por las entidades financieras del SFA
3. Forma parte del **gobierno del SFA y es la fuente de información técnica** durante la publicación inicial y todos los evolutivos

Arquitectura del Directorio y Sandbox del SFA

Roles del Sandbox Pre-Productivo y tipo de Interacción

Participantes del Sistema de Finanzas Abiertas (SFA):

Instituciones Proveedoras de Información / Cuentas (IPI / IPC)

Instituciones participantes del SFA que proveen información financiera y/o permiten el acceso a cuentas, pagos, seguros, créditos, etc , conforme a la Ley Fintec y a la normativa CMF vigente.

Rol dentro del Sandbox Pre-Productivo:

- Realizar el registro de la institución en el directorio
- Realizar pruebas de integración para establecer una conexión entre la entidad financiera y el directorio para la generación de la copia local
- Registrar el servidor de autorización para que otros participantes PSBI/PSIP puedan realizar el registro dinámico de clientes

Opcional:

- Verificar la identidad, vigencia y rol de los PSBI/PSIP a través del Directorio de Participantes
- Validar flujos de consentimiento, autenticación y consumo de información realizados por los PSBI/PSIP participantes

Proveedores de Servicios Basados en Información / Iniciación de Pagos (PSBI / PSIP)

Entidades inscritas en los registros correspondientes de la CMF que consumen APIs del Sistema de Finanzas Abiertas para prestar servicios autorizados por el cliente (SFA).

Rol dentro del Sandbox Pre-Productivo:

- Integrarse técnicamente al ecosistema del SFA mediante el Directorio de Participantes para su posterior registro en la entidad simulada desplegada en el Sandbox
- Ejecutar pruebas funcionales y técnicas contra APIs del Sandbox
- Validar flujos de consentimiento, autenticación y consumo de información.

Opcional:

- Se podrá realizar acuerdos con los participantes para realizar pruebas controladas fuera del entorno sandbox y probar lo que las IPI/IPC tenga habilitado para consumo:
  - DCR
  - APIs Open Data
  - APIs Transaccionales/Iniciación de pagos

El Sandbox Pre-Productivo permite a los participantes del SFA validar, en un entorno controlado y alineado a la normativa CMF, los roles, responsabilidades e interacciones que operarán posteriormente en producción

Arquitectura del Sandbox y su Integración con el Directorio

Conectividad segura y gestión de certificados en el Sandbox

- El Sandbox Pre-Productivo utiliza **certificados digitales** como base del modelo de confianza entre participantes y servicios.
- Para el entorno de pruebas (SSA), se permite el uso de **certificados autofirmados**, exclusivamente con fines de validación técnica.
- Los certificados mTLS permiten establecer **autenticación mutua**, garantizando la identidad tanto del cliente como del servidor.
- Cada participante genera su **par de claves criptográficas** y asocia su certificado mTLS a su identidad dentro del Directorio.
- La validez, vigencia y estado del certificado son verificados antes de permitir cualquier interacción con el Sandbox

- El **Directorio de Participantes** actúa como punto central de referencia para la validación de:
  - identidad del participante,
  - rol autorizado,
  - certificados registrados y metadatos técnicos.
- El Sandbox consulta el Directorio para **verificar la habilitación del participante** previo al establecimiento de la conexión.
- Una vez validado el certificado mTLS, se habilita la **conexión segura** entre el participante y los servicios del Sandbox.
- Todas las interacciones se realizan en un **entorno controlado**, utilizando datos simulados y sin impacto en sistemas productivos.
- Este modelo asegura coherencia entre **seguridad, trazabilidad e interoperabilidad** desde la etapa de pruebas.

Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Usuario recibe un correo con enlace para configurar sus credenciales:

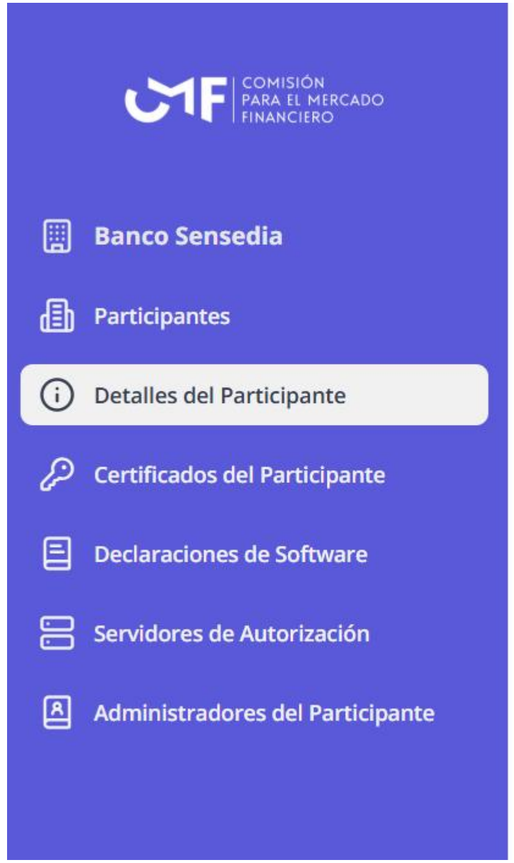
- ❑ Administrador del participante es responsable por registro de nuevos usuarios;
- ❑ Contraseña depende de usuario acceder a enlace enviado por correo electrónico.

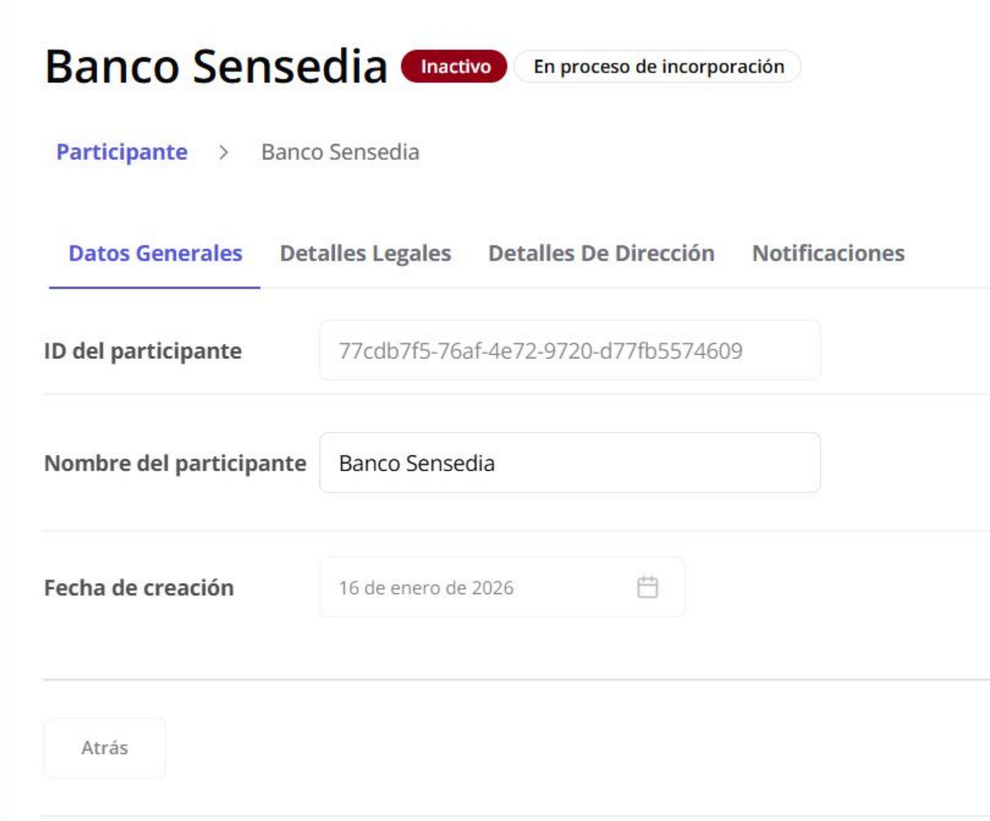
Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Usuario accede Directorio y puede visualizar detalles del Participante:

- Rol Usuario y Administrador pueden visualizar todos los detalles de su organización participante:
  - Datos generales
  - Detalles legales
  - Detalles de dirección
  - Notificaciones



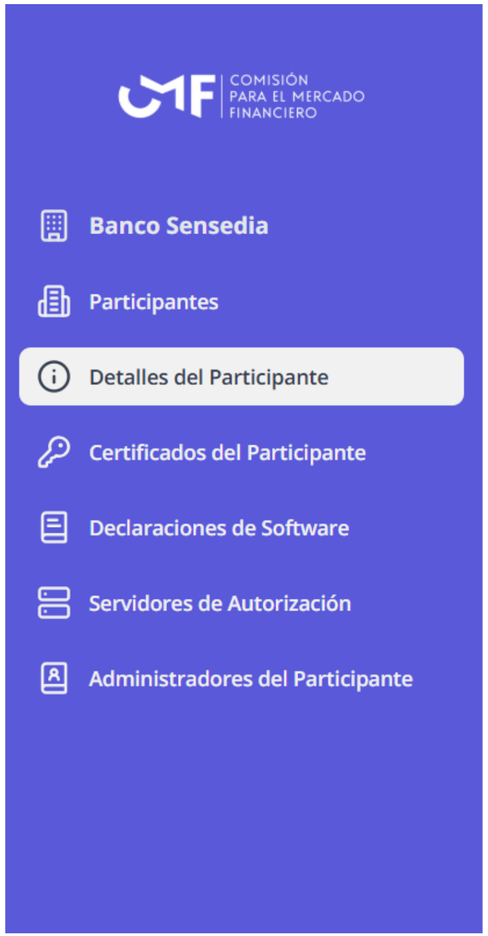


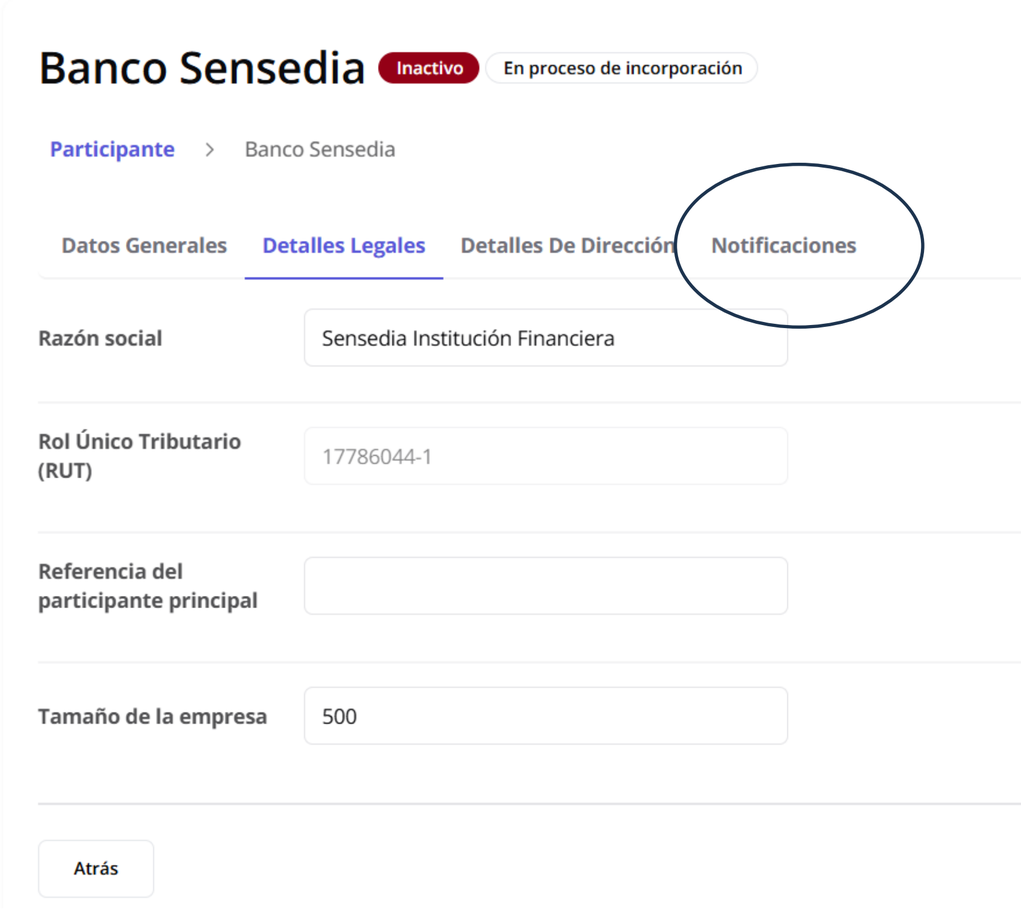
Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Editar datos del Participante:

- Rol Administrador puede editar los siguientes detalles de su organización participante:
  - Datos generales
    - Nombre del participante
  - Detalles legales
    - Razón social
    - Referencia y tamaño de la empresa
  - Detalles de dirección
    - Dirección, referencia, código postal y ciudad
  - Notificaciones
    - URL del Webhook



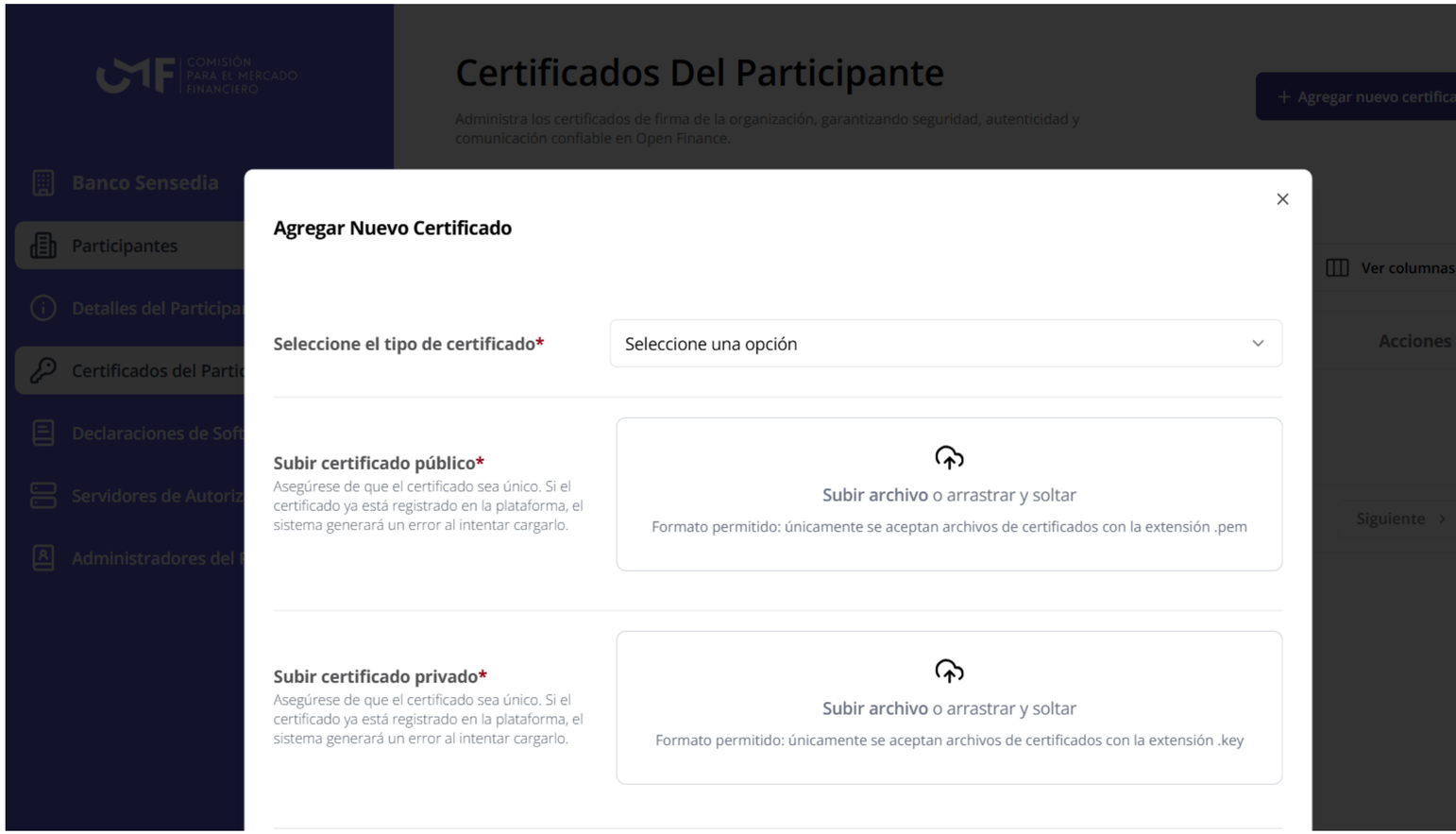


Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Rol Administrador – puede listar y agregar certificados del Participante:

- Certificado público
  - Formato .pem
- Certificado privado
  - Formato .key

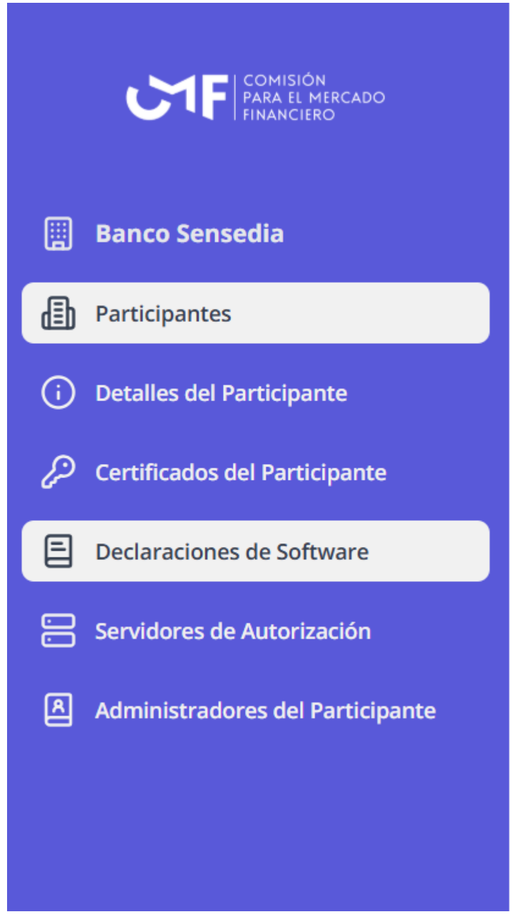


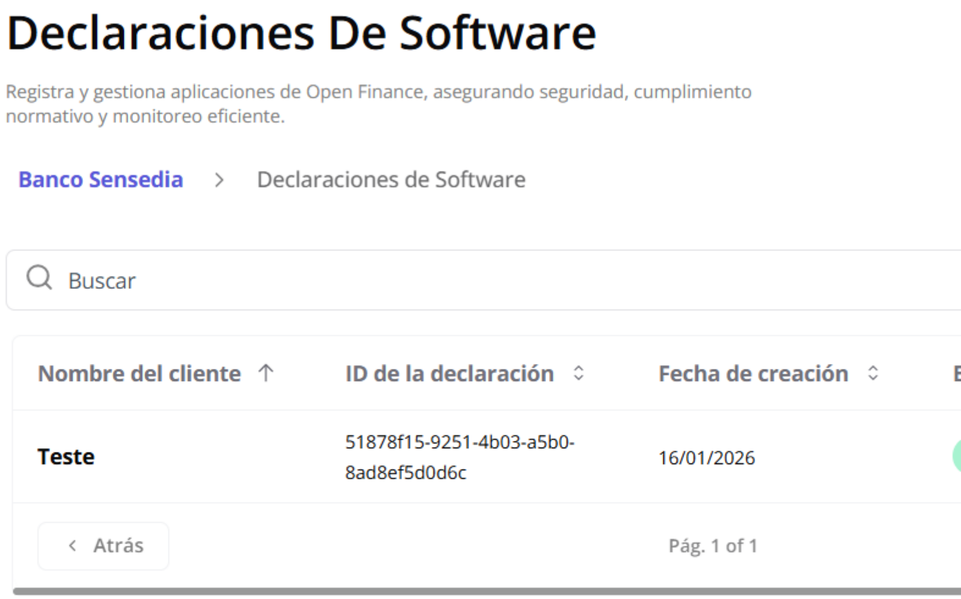
Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Rol Administrador – puede listar y agregar declaración de software del Participante:

- ❑ Datos
  - Nombre del cliente
- ❑ URL
  - URL del cliente
  - URL de términos de servicio
  - URL de la política
  - URL del logotipo
  - URL de redirección
- ❑ Detalles Operativos
  - Ambiente
  - Descripción
  - Versión
  - Creado por



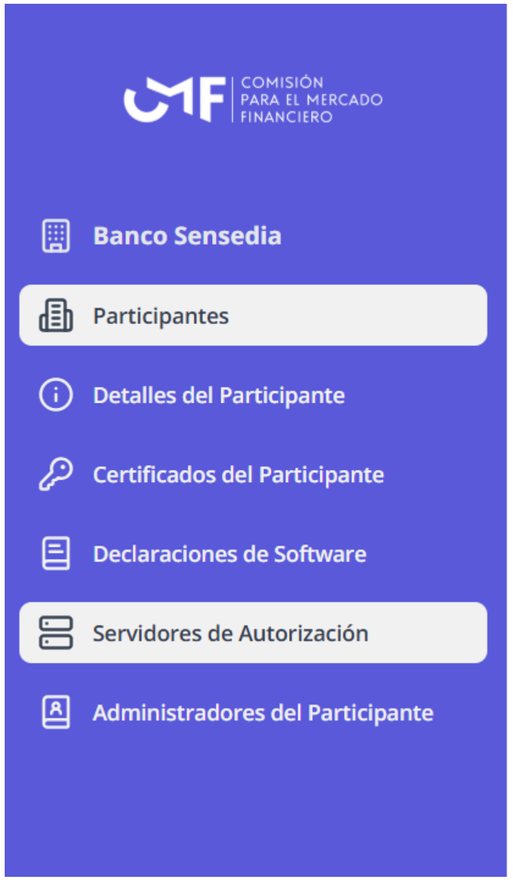


Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Rol Administrador – puede listar y agregar servidores de autorización del Participante:

- Datos
  - Nombre del servidor
  - OpenID – URL de descubrimiento
- URLs
  - Logotipo de la marca
  - Términos de servicio
  - Portal de desarrollador
  - Certificado de firma
- Detalles del Servidor
  - Servidor de autorización padre
  - Descripción

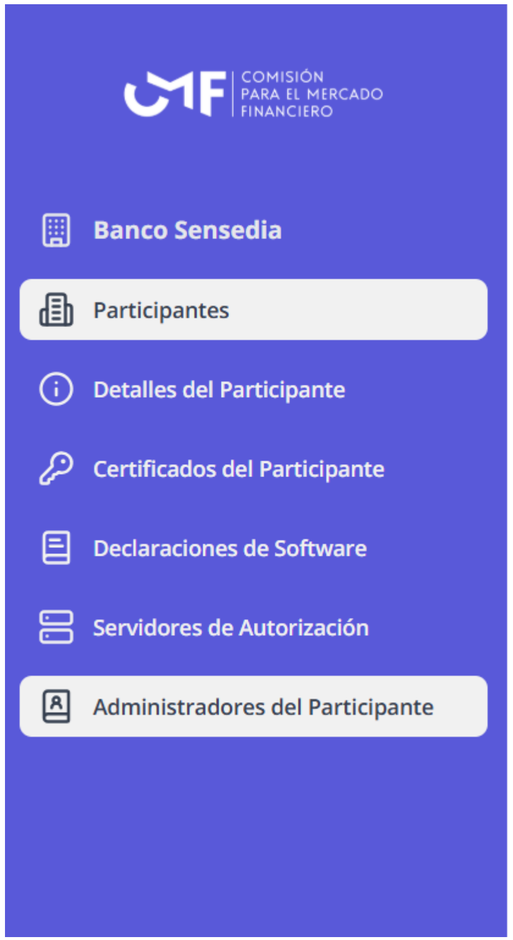


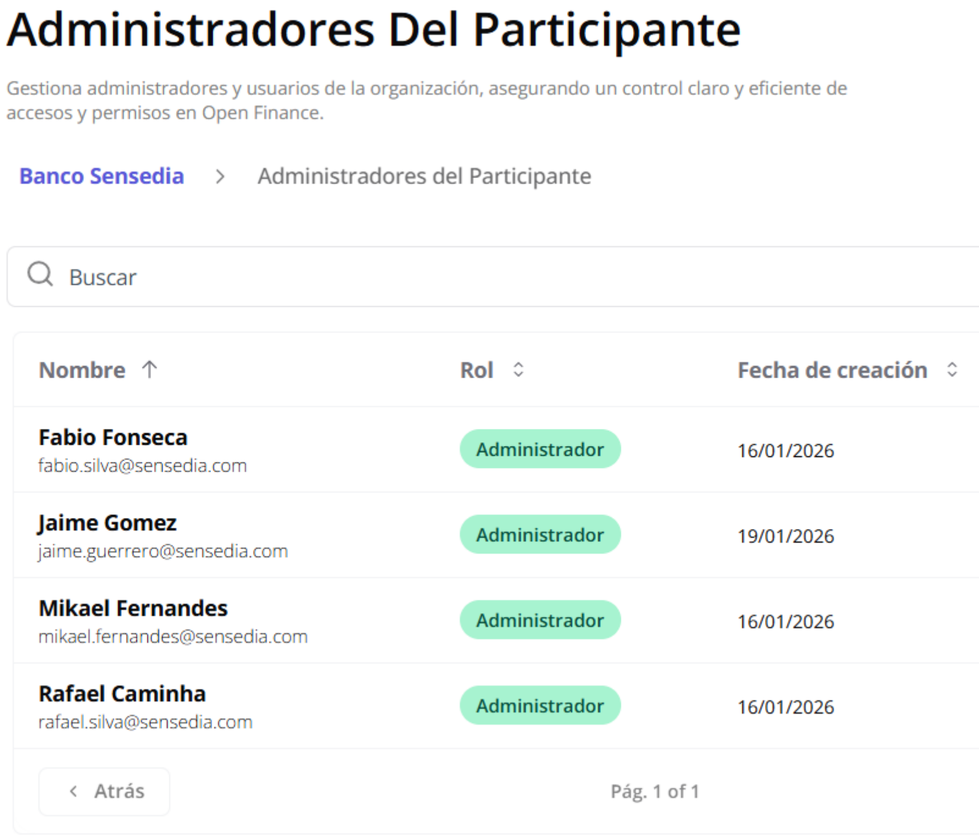
Arquitectura del Sandbox y su Integración con el Directorio

Journey del registro en el Directorio

Rol Administrador – puede listar y agregar otros usuarios del Participante:

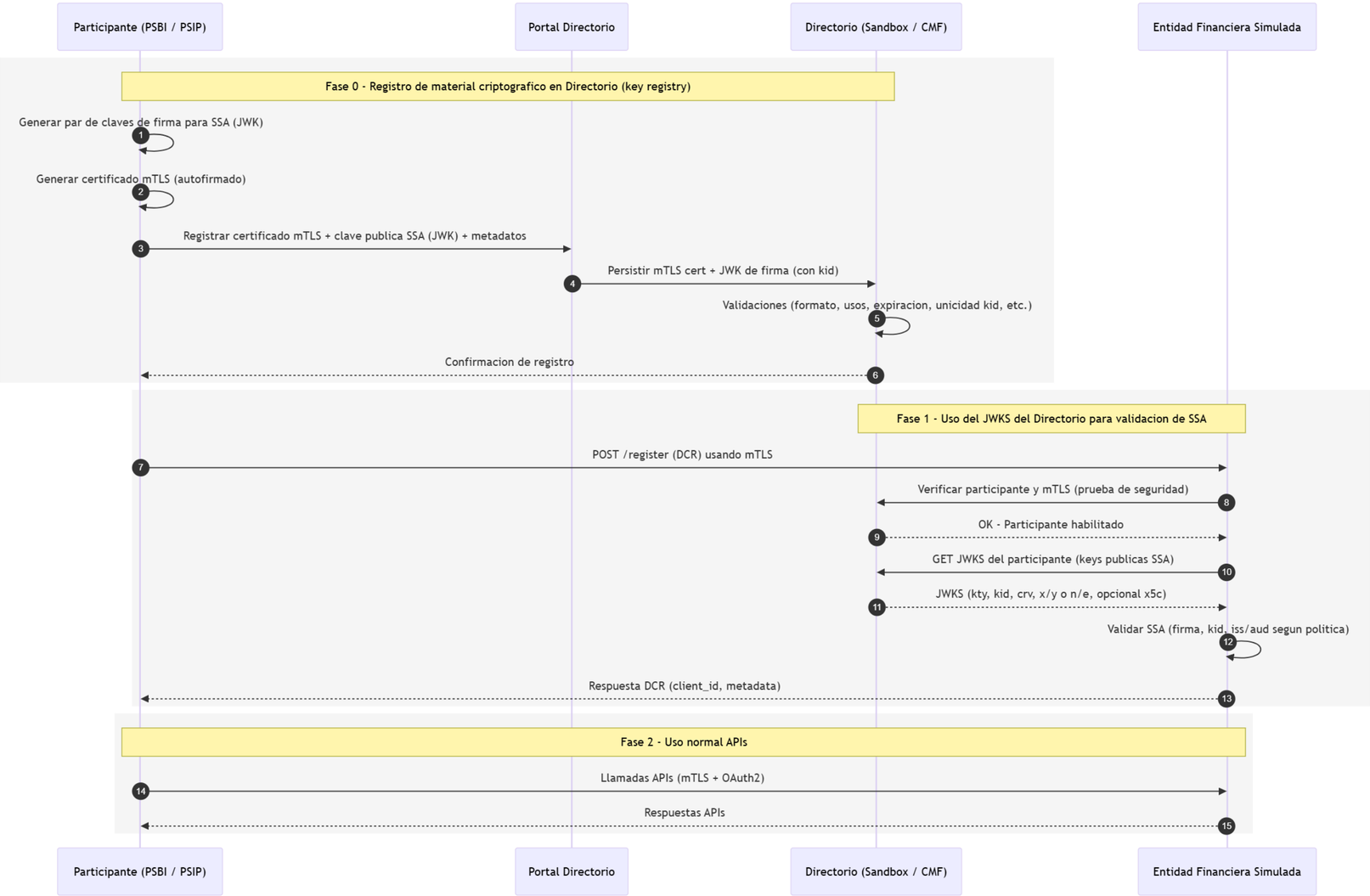
- Datos obligatorios de usuario:
  - Nombre
  - Apellido
  - Correo electrónico
  - Role





Arquitectura del Sandbox y su Integración con el Directorio

Certificados



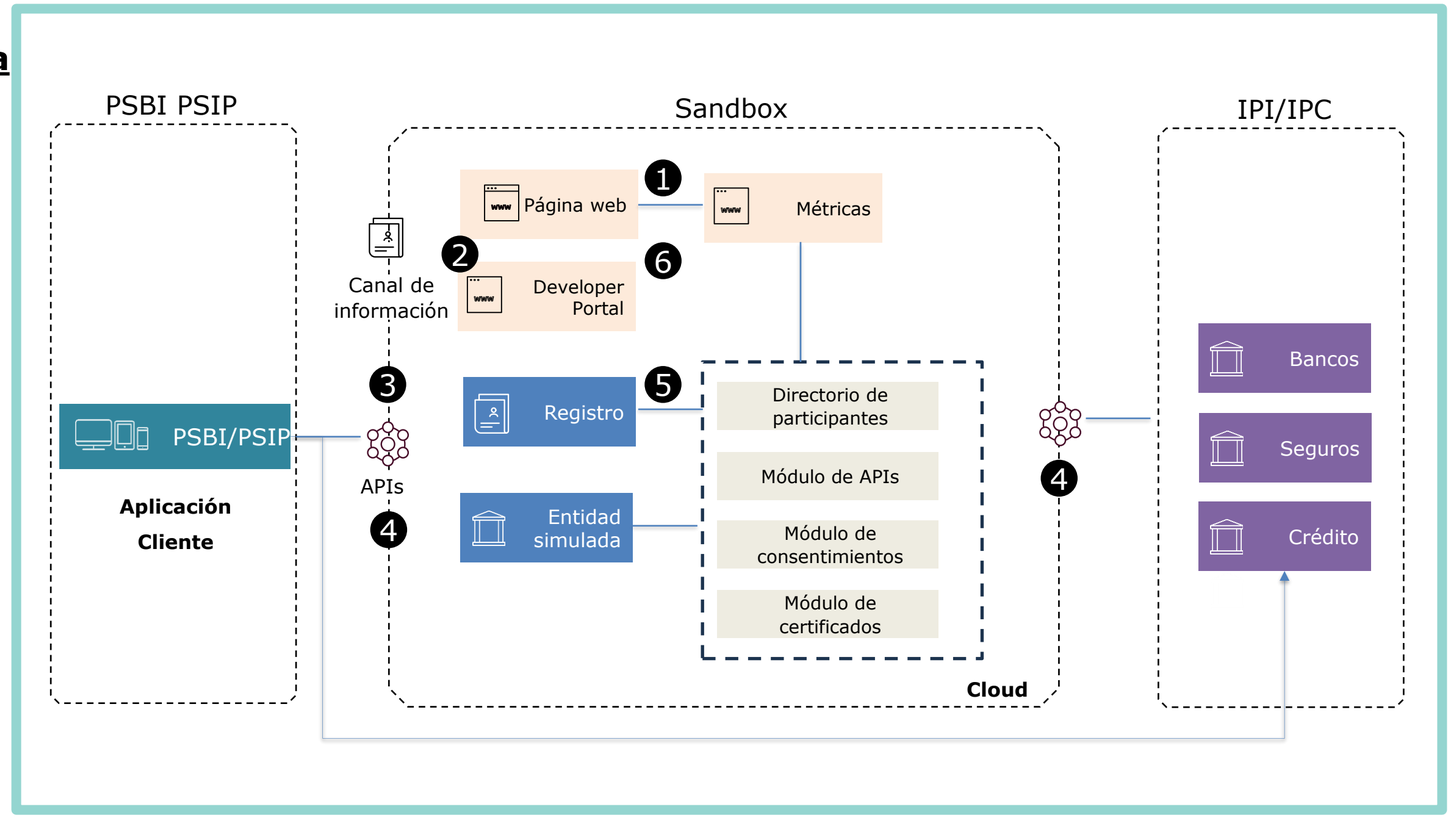
Los certificados autofirmados son válidos exclusivamente para el ambiente Sandbox / preproductivo.
En ambientes productivos se requerirá el uso de certificados emitidos por una Autoridad Certificadora reconocida, conforme a la normativa vigente.

Arquitectura del Sandbox y su Integración con el Directorio

Roles del Sandbox Pre-Productivo y tipo de Interacción

Journey de los participantes en el Sandbox con la entidad financiera simulada (PSBI/PSIP):

1. **Acceso al portal** del desarrollador de la CMF para visualizar información del SFA
2. Consulta de documentación técnica y descarga de **especificaciones OpenAPI** (Swagger) y colecciones de prueba
3. **Ejecución de pruebas de registro y autenticación** mediante el banco simulado y la validación en el Directorio de Participantes del SSA (declaración de software)
4. **Integración de aplicaciones (API Management y Servidor de autorización)**
5. Ejecución de **pruebas y consumo de APIs** en el entorno
6. Participación en instancias de **feedback y foros de discusión del ecosistema**.



COMISIÓN PARA EL MERCADO FINANCIERO

Regulador y Supervisor Financiero de Chile

Presentación Sandbox Tecnológico Pre-Productivo ATENA

finanzasabiertas
COMISIÓN PARA EL MERCADO FINANCIERO

Comisión para el Mercado Financiero
Enero 2026

La preparación para las pruebas será abordada en tres sesiones

Sesión 1
Arquitectura del Sandbox y su integración con el Directorio

- Introducción
- Topología de componentes (Sandbox, Directorio, Entidad Financiera)
- Roles y tipo de interacciones entre cada uno de los actores
- Registro en el directorio y manejo de certificados de seguridad
- Roles del Sandbox Pre-Productivo y tipo de Interacción

Sesión 2
Principios de Diseños y Flujos de Seguridad

- Contratos OpenAPI 3 – principios de diseño
- Comunicación de eventos Direcotorio y Grant Management
- Autenticación mTLS + OAuth/OIDC
- Principios de seguridad del Perfil Chileno FAPI 2.0
- Conexión y captura del consentimientos (RAR)

Sesión 3
DEMO (Fecha por definir)

- Cercano a la fecha de inicio del período de pruebas se realizará lo siguiente:
  - Proceso de alta para generación de accesos al directorio
  - Tipos de pruebas a ejecutar (esperables y evidencias)
  - Niveles de soporte durante el proceso de pruebas
  - Información sobre equipo de soporte
  - DEMO de utilización del ambiente de pruebas

Expositores Sesiones de Preparación Pruebas del Sandbox Tecnológico ATENA

Eduardo Oñate
Director General de Tecnologías de la Información

Roberto Celis
Jefe de proyecto

Jonathan Lema
Open Finance Manager

Rodrigo Escapa
Arquitecto Open Finance

Mikael Fernandes
Product Owner

Jaime Guerrero
Arquitecto de Soluciones

Agenda

01 Contexto

02 Arquitectura del Sandbox y su integración con el Directorio

03 **Principios de Diseños y Flujos de Seguridad para las pruebas**

04 Kick Off: Acceso a entorno pre-productivo

Principios de Diseños y Flujos de Seguridad

Contratos OpenAPI 3.1

Esquema general de Diseño:

1. **Estándar:** uso de **OpenAPI** como contrato oficial para definición y consumo de APIs
2. **Estructura base del contrato:** definición de versión, servidores por entorno, paths/operaciones y esquemas reutilizables
3. **Diseño de recursos:** endpoints definidos como recursos (sustantivos), con naming consistente y estable.
4. **Parámetros y entradas:** uso de *path* para identificación, *query* para filtros/paginación y *requestBody (Ej: Iniciación de pagos, consentimientos, etc)*
5. **Modelo de datos:** esquemas normalizados de acuerdo al estándar ISO20022, reutilizables y separados por propósito (entrada, salida y errores)
6. **Respuestas y errores:** uso de códigos HTTP estándar y estructura homogénea de errores
7. **Versionamiento y claridad:** control explícito de versiones y prevención de cambios incompatibles sin versionar.

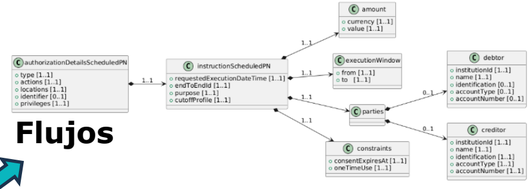
¿Qué contiene el Portal del Desarrollador?

- Documentación funcional y técnica del ecosistema Open Finance
- Catálogo de APIs disponibles en el Sandbox
- Especificaciones OpenAPI descargables
- Guías de integración y lineamientos de diseño
- Acceso a métricas de uso y adopción (cuando aplique)
- Espacios de soporte, feedback y comunicación con el ecosistema

APIs

- Las APIs se organizan por dominio funcional (información, pagos, consentimiento, etc.)
- El catálogo puede evolucionar en el tiempo, incorporando nuevas versiones o APIs
- Cada API cuenta con un contrato versionado y trazable

Flujos



Diccionario de Datos

Authorization Details — Pago Único Programado — Persona Natural (PN)

Name	Glosa Field Name	ISO20022 Type	JSON Data Type	Cardinalidad	Mandatory	Ejemplo	Observaciones
type	Tipo de autorización	Max40Text	string	1..1	Si	scheduled-payments	Tipo fijo para pagos programados
actions	Acciones solicitadas	Array	array	1..1	Si	["CreateScheduledPayments"]	User CreateScheduledPayments o ReadScheduledPayments
locations	Ubicaciones/endpoints	Array	array	1..1	Si	["v1/PN/scheduled-payments"]	Endpoint expuesto para PN

Ejemplos

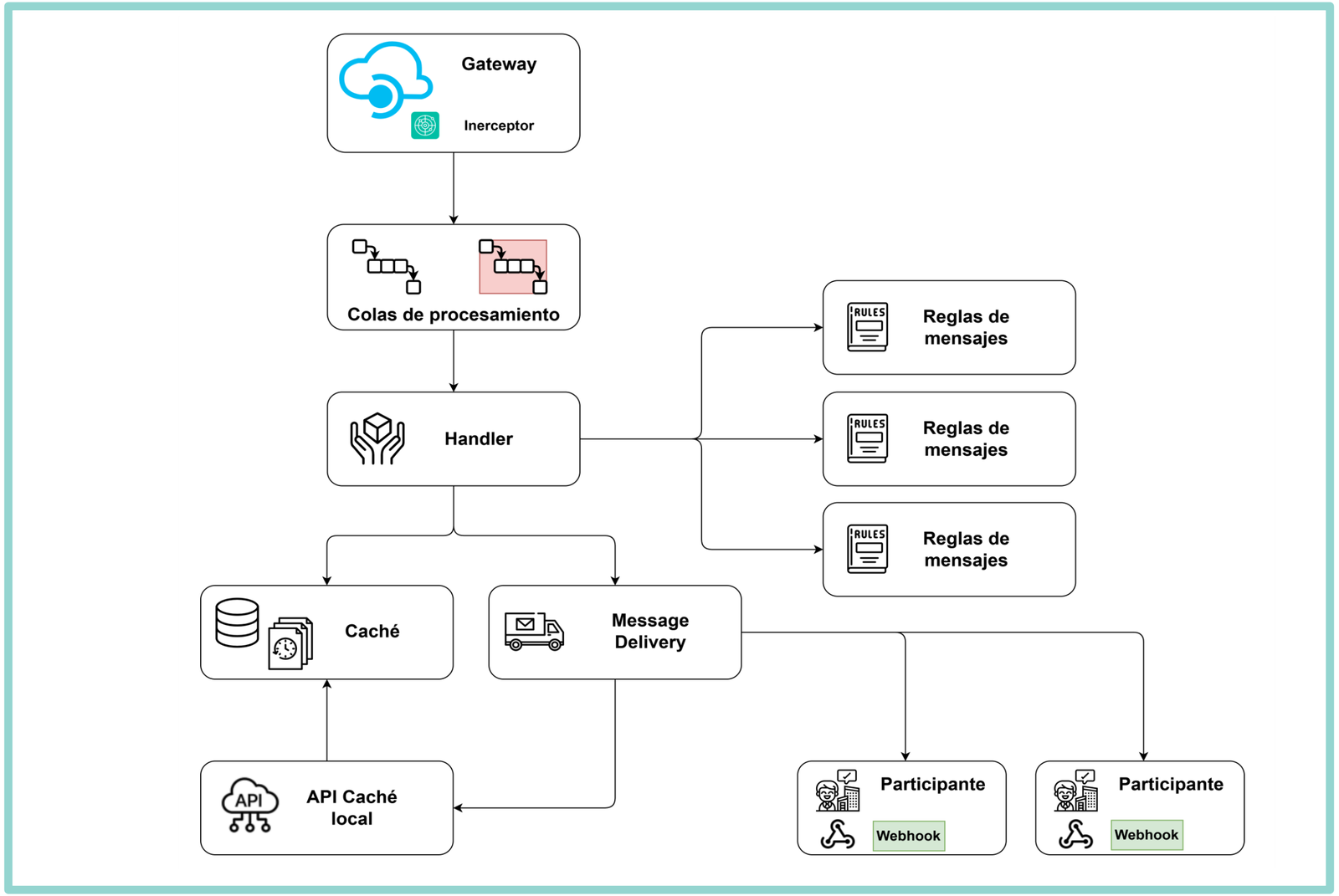
Ejemplo de petición

```
POST /authorizations/v1/PN/scheduled-payments HTTP/1.1
Host: api.chilebank.cl
Authorization: Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...<token>...
x-fapi-interaction-id: a8f92c4d-6c71-4e8c-b4e1-9a6b5f123456
x-jws-signature: eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9...<firma>...
Content-Type: application/json
Accept: application/json

{
  "type": "scheduled-payments",
  "actions": [
    "CreateScheduledPayments",
    "ReadScheduledPayments"
  ],
  "locations": [
```

Principios de Diseños y Flujos de Seguridad

Comunicación de Eventos del Directorio



Webhook

- Componente encargado de realizar notificaciones en el sentido Directorio -> Participantes

Principios de Diseños y Flujos de Seguridad

Consulta pública de datos de Participantes

El flujo de mensajería está directamente vinculado a los **flujos de participación de los participantes**, al mantenimiento del flujo interoperable del participante y en el flujo administrativo de la CMF que se refiere tanto a las acciones de control de suspensiones como a la cancelación de un participante.

Flujos	Tipo	¿Quién actúa?	¿Envía mensaje?
Activación de participante	Engagement	• CMF	✅
Inactivación de participante	Engagement	• CMF • Participante	✅
Reactivación de participante	Engagement	• CMF • Participante	✅
Cancelación de participante	Flujo administrativo	• CMF	✅
Otras funcionalidades	-	-	⛔

API Directorio de Participantes Offline

api.desarrollo.finanzasabiertas.cl/public/v1/participants

Estilos de formatação


```
[
  {
    "organisationId": "923146f6-b54f-4773-a6d8-a4db2a794afe",
    "organisationName": "Banco Mengao",
    "companyRegister": "Finaciero",
    "addressLine1": "Carrera 123",
    "addressLine2": "oficina",
    "city": "Santiago",
    "postcode": "162314",
    "country": null,
    "status": "ACTIVE",
    "authorisationServers": [
      {
        "authorisationServerId": "64cf4a23-7873-4d9b-8a83-9dd58ac60367",
        "customerFriendlyName": "SA-mengao",
        "issuer": "http://k8s-oidc-98e38a3689-1505699949.us-east-1.elb.amazonaws.com/",
        "status": null,
        "apiResources": [
          {
            "apiResourceId": "1da120ff-fd75-40a0-be3f-1a6fd0f43555",
            "apiVersion": "001",
            "status": "Awaiting_Certification",
            "apiDiscoveryEndpoints": []
          }
        ]
      }
    ],
    "softwareStatements": [
      {
        "id": "1d0c0b18-3123-42fd-84c9-f4ba83a11df7",
        "clientName": "mengao-ss-quatro",
        "clientUri": "http://google.com",
        "logoUri": "http://google.com",
        "termsOfServiceUri": "http://google.com",
        "policyUri": "http://google.com",
        "version": "4",
        "mode": null,
        "status": "Active"
      },
```


¿Qué contiene?

- Esta API es un mecanismo para que los participantes tengan una copia local del directorio y no dependan en tiempo real del directorio central.
- Qué información contiene:
  - Datos públicos del participante
  - Direcciones del servidor de autorización
  - APIs de Recursos (Dirección Apis Reguladas)
  - Software Statement Registrados

Principios de Diseños y Flujos de Seguridad

Comunicación de Eventos

Grant Management

Modelo general

- La comunicación de eventos es **asíncrona**, basada en **webhooks**
- Cada cambio relevante en el ciclo de vida de un **grant** genera un **evento notificable**
- Los eventos **no transportan datos sensibles** ni el detalle completo del consentimiento
- El receptor debe **consultar la Grant Management API** para obtener el estado actualizado

Tipología de eventos

- Creación de consentimiento (Authorised)
- Rechazo del consentimiento (Rejected)
- Revocación del consentimiento (Revoked)
- Expiración del consentimiento (Expired)
- Fallos del proceso (Failed / Incomplete)

Principios clave

- Entrega **al menos una vez** con posibilidad de reintentos
- **Orden garantizado** por event.sequence para un mismo grant_id.
- Trazabilidad obligatoria con retención ≥ 5 años.
- El grant_id actúa como **identificador único del evento** y del recurso afectado.

```
POST /webhooks/sfa HTTP/1.1
Content-Type: application/cloudevents+json
X-Signature: eyJhbGciOiJSUzI1NiIsImtpZCI6IjNkYzI4...
X-Idempotency-Key: 61a8e3b6-4b7b-4934-b09e-01c2391e78a7
X-Timestamp: 2025-01-15T14:32:10Z
X-Nonce: a92fbc31


{
  "specversion": "1.0",
  "type": "sfa.consent.revoked",
  "source": "https://api.ipi.cl/grants",
  "subject": "grant:8f3a2c9e-2b14-4a9c-9c21-1c3b9e9f12ab",
  "time": "2025-01-15T14:32:10Z",
  "datacontenttype": "application/json",
  "data": {
    "previousState": "Authorised",
    "newState": "Revoked",
    "reason": "psu_request"
  },
  "event": {
    "sequence": 42,
    "streamId": "grant:8f3a2c9e-2b14-4a9c-9c21-1c3b9e9f12ab"
  }
}
```

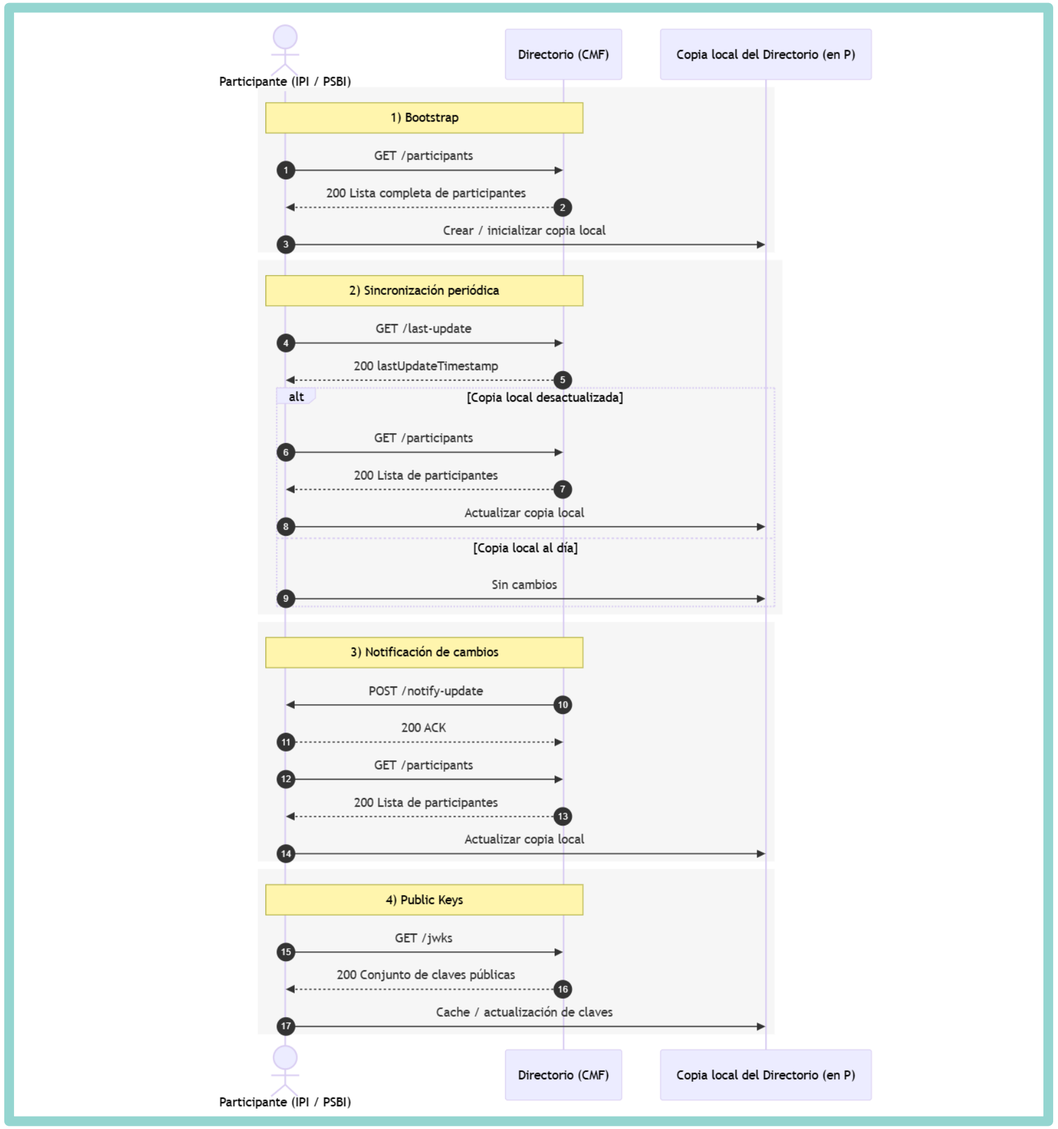
```
GET /grants/8f3a2c9e-2b14-4a9c-9c21-1c3b9e9f12ab
Authorization: Bearer <access_token>


{
  "grant_id": "8f3a2c9e-2b14-4a9c-9c21-1c3b9e9f12ab",
  "state": "Revoked",
  "revokedAt": "2025-01-15T14:32:10Z"
}
```

Principios de Diseños y Flujos de Seguridad

Sincronización con el Directorio

- El Directorio expone endpoints como /participants, /last-update, /public-keys y endpoints de mensajería
- El participante debe consultar /last-update al menos cada 8 horas y, si detecta cambios, descargar /participants para actualizar su copia local
- El diseño busca ser “base de datos liviana” y desacoplado del plano transaccional, usando patrón publish/subscribe (RFC 7641) y copia local.



Principios de Diseños y Flujos de Seguridad

Perfil de Seguridad

Objetivo y Enfoque:

Se establece un marco común de seguridad para la interacción de los participantes con el Portal del Desarrollador del Sistema de Finanzas Abiertas, alineado con estándares internacionales, que garantice control de accesos, integridad de la información y trazabilidad, de forma consistente en los distintos entornos operativos.

Mapa de Contenido:

Perfil de Seguridad FAPI2.0 versión Chilena

Define los requisitos mínimos de seguridad que deben cumplir todos los participantes del ecosistema adaptados a Chile, tomando como referencia el trabajo de los grupos técnicos

Rich Authorization Requests (RAR)

Establece los mecanismos para la expresión y control de consentimientos y alcances de acceso

Grant Management

Regula la administración del ciclo de vida de las autorizaciones otorgadas, incluyendo su emisión, uso y revocación

Casos de Error vinculados a Seguridad

Estandariza el tratamiento y comunicación de errores de seguridad, asegurando coherencia y trazabilidad

Dynamic Client Registration (DCR)

Define el proceso de registro dinámico de clientes, incorporando validaciones y controles de seguridad

Firma Digital de Mensajes y Payloads

Establece los lineamientos para la firma, verificación e integridad de los mensajes intercambiados

Especificación de Webhooks SFA

Regula el uso de notificaciones seguras asociadas a eventos relevantes del sistema

Reglas de Redirección Segura entre Aplicaciones

Define controles para garantizar redirecciones seguras, mitigando riesgos de uso indebido

Estos lineamientos establecen el marco común de seguridad del ecosistema; su implementación técnica detallada se encuentra disponible en el Portal del Desarrollador

Principios de Diseños y Flujos de Seguridad

Conexión y captura del consentimiento

Conexión y autenticación

- Establecimiento de **conexión segura** mediante **mTLS**, validando identidad del participante y del servidor
- Autenticación basada en **OAuth 2.0 / OpenID Connect**, conforme al perfil especificado en el portal del desarrollador
- **Validación previa del rol del participante** y su habilitación en el Directorio.
- Garantía de **confidencialidad, integridad** y no repudio en las comunicaciones

Construcción del authorization_details (RAR)

- Definición explícita y estructurada de los **permisos solicitados** (datos u operaciones)
- Inclusión de restricciones como tipo de recurso, acciones permitidas y contexto de uso
- Reemplazo de scopes genéricos por **autorizaciones granulares y específicas**
- Base para la captura informada y verificable del consentimiento del cliente

Petición del token

- Solicitud de **access token** al Authorization Server utilizando el Flujo de PAR
- **Asociación explícita** del token al cliente, al software registrado y al contexto de la autorización
- Emisión de tokens con **alcance limitado**, duración controlada y mecanismos de revocación
- Uso de **tokens firmados** para asegurar trazabilidad y validación del emisor

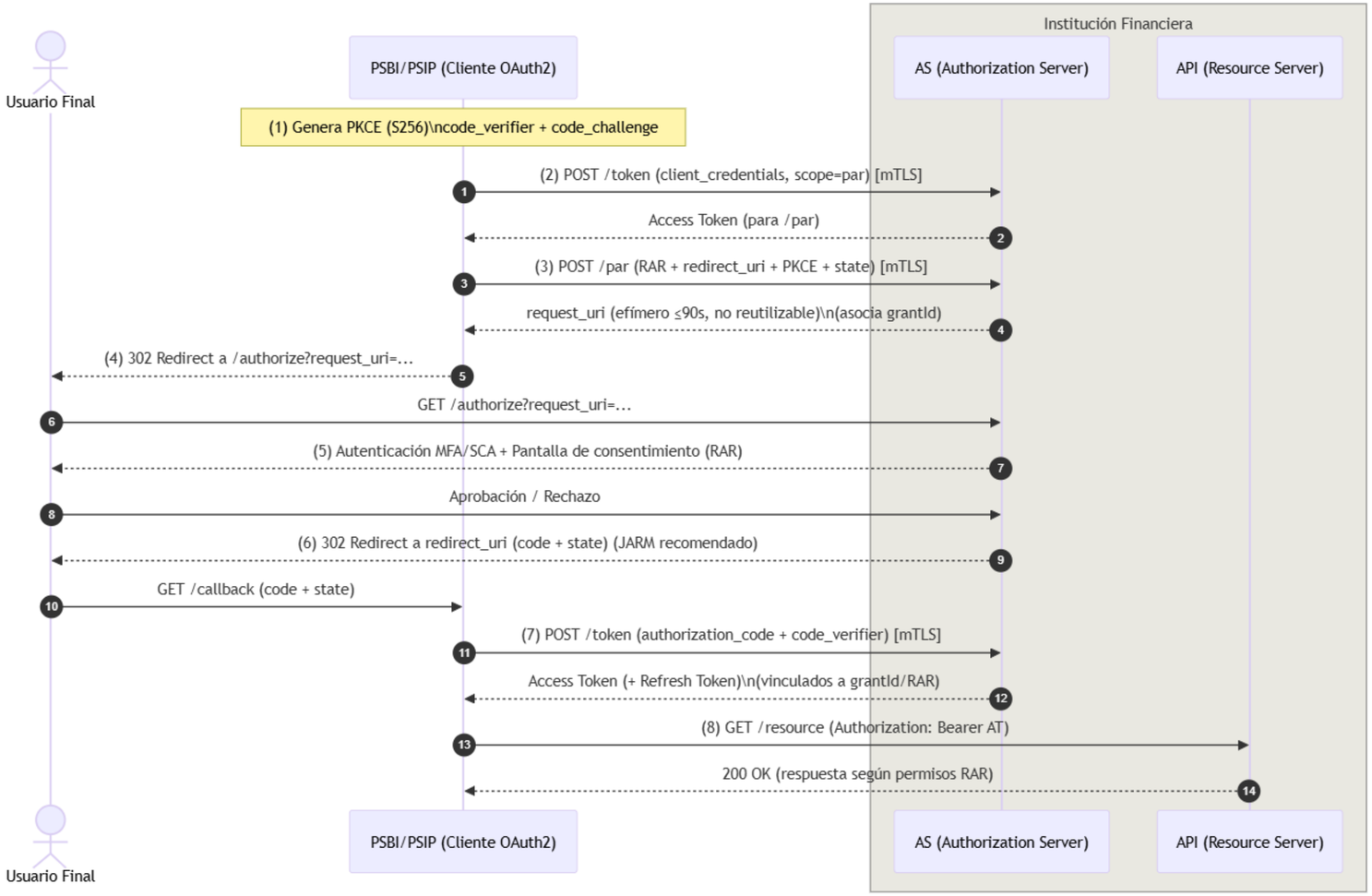
Grant Management

- Creación y registro del **grant** asociado al consentimiento otorgado por el cliente
- Administración del **ciclo de vida del consentimiento** (vigente, expirado, revocado)
- Verificación del estado del grant antes de permitir el acceso a las APIs
- Trazabilidad y control centralizado del uso del consentimiento en el tiempo

La construcción de los flujos se ha realizado siguiendo el estándar FAPI2.0 y las adaptaciones sugeridas por la industria durante las mesas técnicas realizadas en el foro consultivo

Principios de Diseños y Flujos de Seguridad

Conexión y captura del consentimiento



Principios de Diseños y Flujos de Seguridad

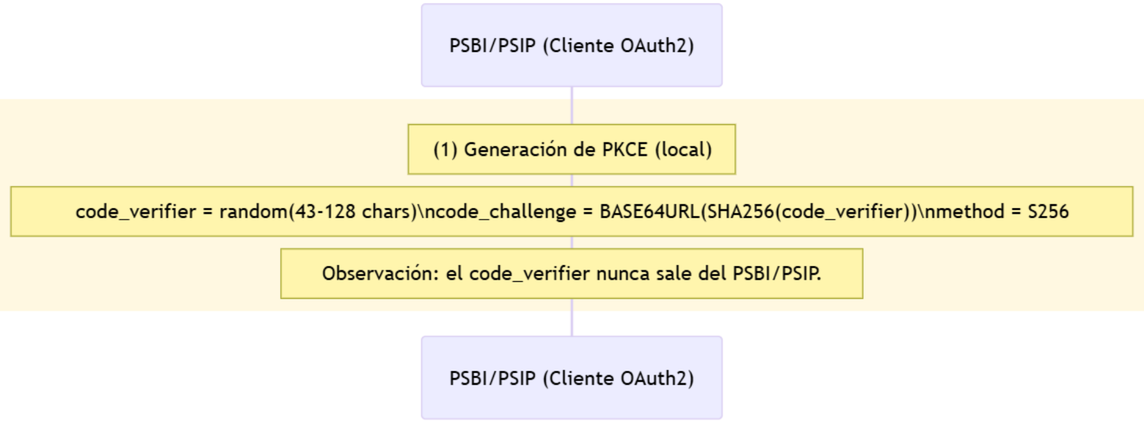
Conexión y captura del consentimiento

Generación de PKCE (PSBI/PSIP)

- El PSBI genera el material criptográfico PKCE para vincular el Authorization Code a la sesión del cliente

Petición

code_verifier = random(43-128 chars)
code_challenge = BASE64URL(SHA256(code_verifier))
method = S256



Principios de Diseños y Flujos de Seguridad

Conexión y captura del consentimiento

Obtención de Access Token para invocar PAR

- El PSBI obtiene un Access Token técnico para poder llamar al endpoint /par

Petición

POST /token
Content-Type: application/x-www-form-urlencoded
(mTLS)

grant_type=client_credentials
scope=par

Principios de Diseños y Flujos de Seguridad

Conexión y captura del consentimiento

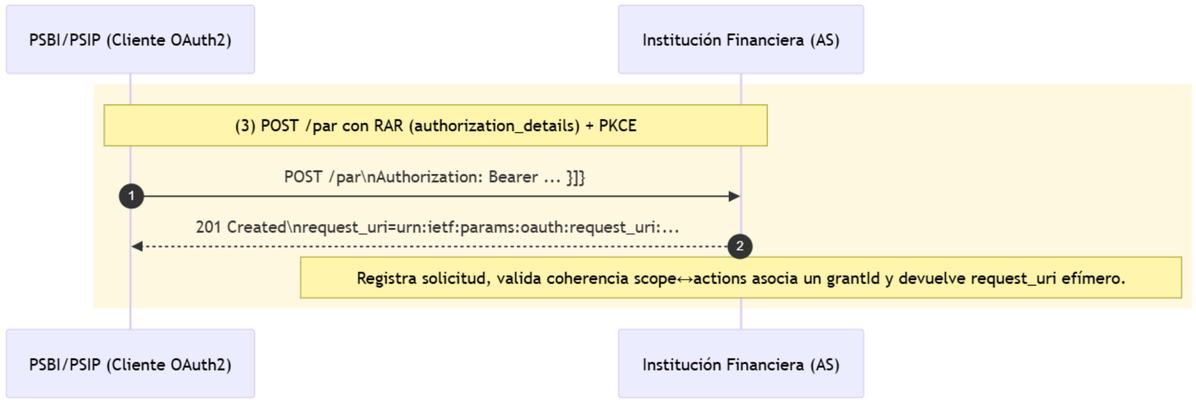
Pushed Authorization Request con RAR

- El PSBI registra la solicitud de autorización completa (PAR + RAR) directamente en el AS.

Petición

POST /par
Authorization: Bearer <access_token>
Content-Type: application/json
(mTLS)

```
{
  "redirect_uri": "https://psbi.app/callback",
  "state": "abc123",
  "code_challenge": "xyz...",
  "code_challenge_method": "S256",
  "authorization_details": [{
    "type": "Accounts",
    "actions": ["ReadAccounts", "ReadTransactions"],
    "identifier": "ACC12345",
    "purpose": "personal_finance_management",
    "recurringIndicator": true,
    "frequency": "R/2025-05-01T00:00:00Z/P1M",
    "validTo": "2026-04-22T00:00:00Z",
    "consentType": false
  }]
}
```



Principios de Diseños y Flujos de Seguridad

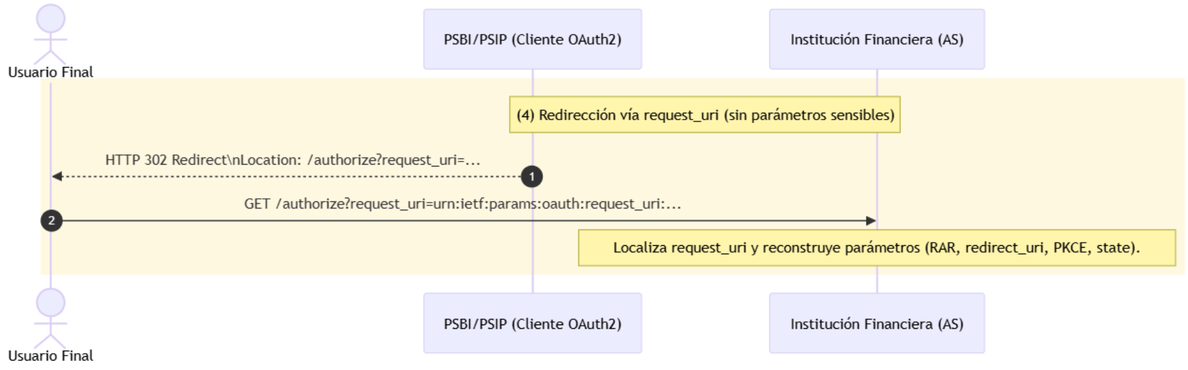
Conexión y captura del consentimiento

Redirección del Usuario usando request_uri

- El PSU es redirigido al AS **sin exponer parámetros sensibles**.
- El request_uri:válido ≤ 90 segundosno reutilizable
- No se permiten scopes, RAR ni redirect_uri en la URL

Petición

GET /authorize?request_uri=urn:ietf:params:oauth:request_uri:xyz



Principios de Diseños y Flujos de Seguridad

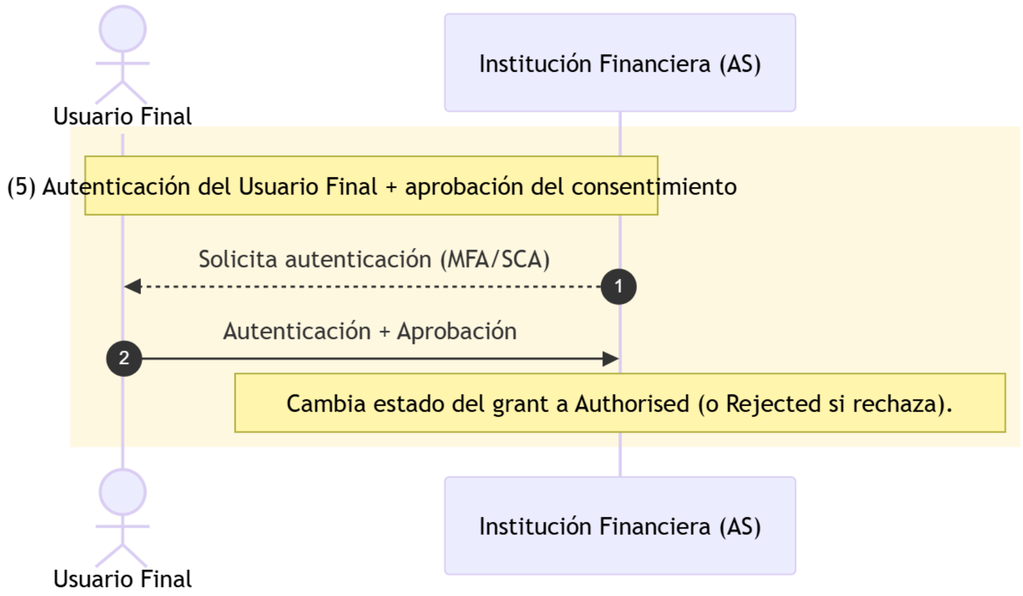
Conexión y captura del consentimiento

Autenticación del Usuario Final y aprobación del consentimiento

- El AS autentica al PSU y presenta el consentimiento derivado del RAR.

Petición

/authorize (interacción UI)



Principios de Diseños y Flujos de Seguridad

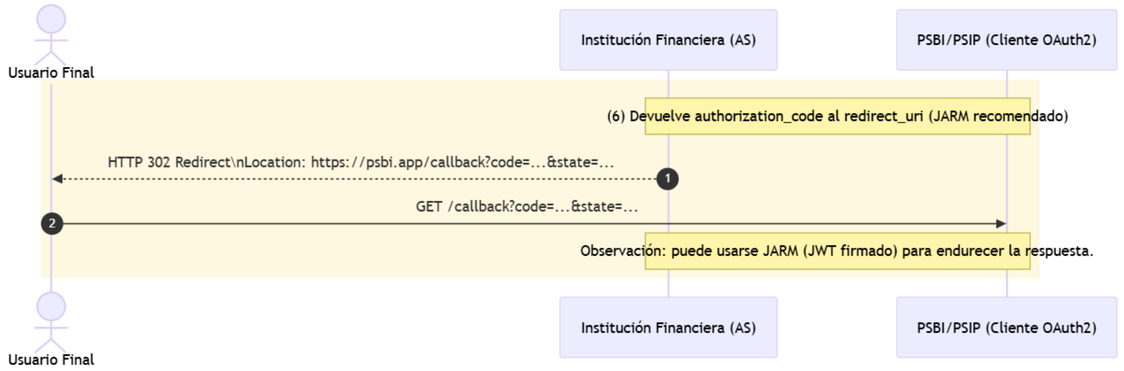
Conexión y captura del consentimiento

Redirección al PSBI con Authorization Code

El AS devuelve el Authorization Code al PSBI/PSIP.

Petición

GET https://psbi.app/callback?
code=abc123
&state=xyz



Principios de Diseños y Flujos de Seguridad

Conexión y captura del consentimiento

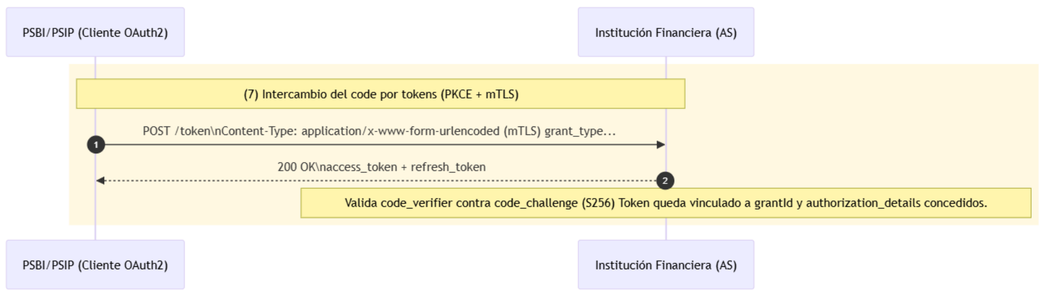
Intercambio del code por tokens

- El PSBI/PSIP intercambia el Authorization Code por tokens finales
- Validación PKCE obligatoria
- Tokens ligados al cliente (mTLS)
- Tokens vinculados al grant / RAR concedido

Petición

POST /token
Content-Type: application/x-www-form-urlencoded
(mTLS)

grant_type=authorization_code
code=abc123
code_verifier=secret_value
redirect_uri=https://psbi.app/callback



Principios de Diseños y Flujos de Seguridad

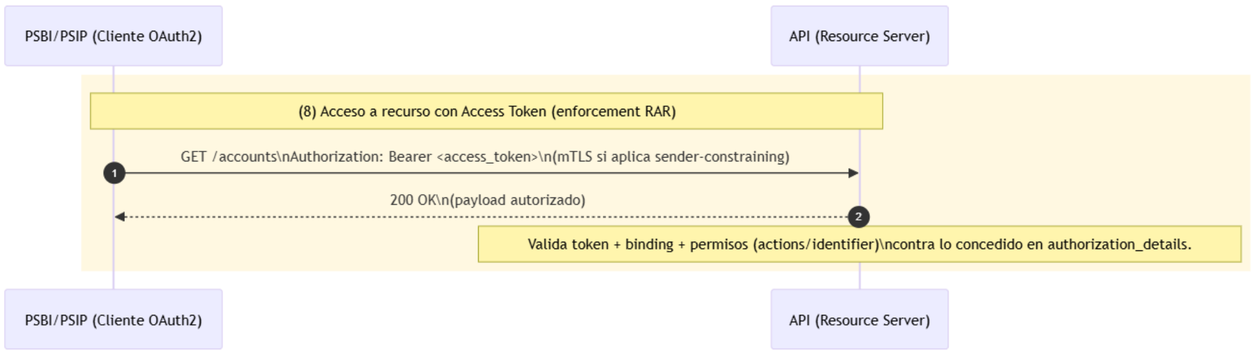
Conexión y captura del consentimiento

Consumo de la API con Access Token

- El PSBI/PSIP intercambia el Authorization Code por tokens finales
- El Resource Server valida:
  - Token
  - binding mTLS
  - permisos contra RAR
- Enforcement por acción y recurso

Petición

GET /accounts
Authorization: Bearer <access_token>



Pruebas de Acceso Sandbox + Directorio

Alcance General

El objetivo es **validar, registrar y evidenciar** de forma trazable el proceso de acceso y **habilitación de los participantes al Sandbox Tecnológico, utilizando el Directorio** como mecanismo de registro y verificación.

Para facilitar su ejecución, la batería de pruebas se divide por rol en dos bloques:

Pruebas Rol IPI / IPC

- ❑ **Onboarding y habilitación de entidad**
- ❑ **Sincronización con el Directorio Certificados y conectividad segura** (mTLS / firma)
- ❑ **Exposición de capacidades de seguridad del AS** (metadata OIDC/OAuth y endpoints)

Pruebas con externos

- ❑ **Registro dinámico de clientes (DCR)** (Validación de integración para SSA)
- ❑ **Consentimiento y Grant Management** (creación, estados y control del acceso)
- ❑ **Exposición/ejecución de APIs** (respuestas y errores estándar)
- ❑ **Revocación y bloqueo posterior de acceso**

Pruebas Rol PSBI / PSIP

- ❑ **Onboarding y habilitación de entidad**
- ❑ **Configuración en Directorio** (datos del participante + callbacks/redirects + metadata)
- ❑ **Certificados y conectividad segura** (mTLS / firma)
- ❑ **Declaración de software (SSA) + JWKS**
- ❑ **Registro dinámico de clientes (DCR)** (registro del cliente en AS).
- ❑ **Autenticación y obtención de tokens** (flujo end-to-end)
- ❑ **Consentimiento con permisos granulares (authorization_details / RAR)**
- ❑ **Consumo de APIs en Sandbox** (con token válido)
- ❑ **Revocación y validación de acceso denegado**
- ❑ **Límites operacionales y manejo de tráfico**

Los casos de prueba van enfocados netamente al acceso y se ejecutarán en Sandbox Pre-Productivo y Directorio, registrando evidencias y métricas de resultado por rol

COMISIÓN
PARA EL MERCADO
FINANCIERO

Regulador y Supervisor Financiero de Chile

Gracias

finanzasabiertas
COMISIÓN PARA EL MERCADO FINANCIERO